

Access Control in Healthcare Systems

Giuseppe Pisano
g.pisano@unibo.it

Healthcare Data Privacy and Security

August, 2026



S.K.I.L.L.E.D — AID013244/04/2

Strategic Knowledge and Inclusive Lifelong Learning in the health sector for youth Employability and Development

- 1 Access Control Purpose
- 2 Authentication, Authorization, Audit
- 3 Policy Design Principles
- 4 Subjects, Objects, and Rights
- 5 Discretionary Access Control
- 6 Mandatory Access Control
- 7 Role-Based Access Control

8 Choosing and Combining Models

Learning path

We move from the **purpose** of access control, to the **decision flow**, then to **policies, subjects and objects**, and finally to the main access-control models: **DAC, MAC, and RBAC**.

Hospital storyline

We continue with St. Isidore Hospital. A doctor, nurse, lab technician, billing clerk, system administrator, medical device, and external specialist all need access, but not to the same data, not with the same actions, and not in every circumstance.

Where this fits

Access control turns security goals into operational decisions: **who** can do **what**, to **which resource**, under **which conditions**, and with **which traceability**.

- **Basic networking**: access decisions protect services exposed on the network.
- **Encryption**: access control decides who may use keys and decrypt data.
- **Authentication**: identity evidence comes before authorization.
- **GDPR**: access must support confidentiality, accountability, minimization, and auditability.

Access Control Purpose

Section Context: Access Control Purpose

What we are talking about

Access control is the security function that mediates every attempt to use a protected resource. It prevents unauthorized use, but also prevents **misuse by authorized users**.

Hospital lens

A cardiologist may be authorized to open the EHR, but that does not mean they may export every patient record, alter medication orders outside their ward, or read celebrity patient files out of curiosity.

Definition

Core idea

Access control implements a security policy specifying **who or what** may access a system resource, **which operation** is allowed, and **under which circumstances** [Shirey, 2007].

Hospital example

The patient portal allows a patient to read their own lab results. It does not allow that patient to read another patient's discharge summary or modify the physician's diagnosis.

Three Goals

Access control should

- block access by **unauthorized** subjects;
- stop **authorized** subjects from using resources in unauthorized ways;
- allow legitimate users to complete legitimate work.

Hospital example

A nurse on the surgical ward should be able to update vital signs for assigned patients, but not change radiology reports or browse psychiatric notes for unrelated patients.

Why It Is Central

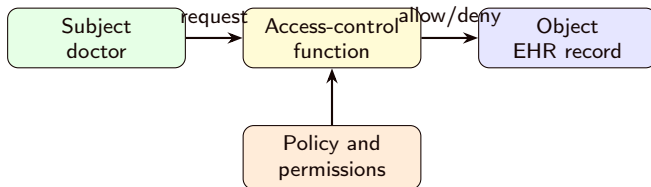
Security as mediation

Many security mechanisms eventually support an access decision. Firewalls mediate network flows; operating systems mediate files and processes; databases mediate records and fields; applications mediate business actions.

Hospital example

The same access-control question appears when a clinician logs into the EHR, when a pharmacy system receives a medication order, and when a backup server reads encrypted database snapshots.

Scheme: Access Request



Reading the scheme

The user does not access the resource directly. A trusted mediation point evaluates the request against policy before the operation is executed.

Recap: Access Control Purpose

Takeaways

- Access control is about **authorized use**, not only login.
- The decision combines subject, object, operation, and context.
- In healthcare, correct access is also a patient-safety requirement.

Authentication, Authorization, Audit

Section Context: AAA

What we are talking about

Access control depends on three related functions: **authentication**, **authorization**, and **audit**. They answer different questions and should not be confused.

Hospital lens

The hospital first checks that “Dr. Rossi” is really Dr. Rossi. Then it checks whether that role may prescribe for this patient. Later, audit logs allow review of what happened.

Authentication

Question

Authentication verifies that the entity presenting credentials is who or what it claims to be.

Hospital example

A doctor uses a password plus a smart card. A medication dispensing cabinet authenticates itself to the pharmacy server using a device certificate.

Authorization

Question

Authorization determines which permissions the authenticated entity has for a requested resource and operation.

Hospital example

After login, the EHR checks whether the doctor has an active care relationship with the patient and whether prescribing is allowed for that department.

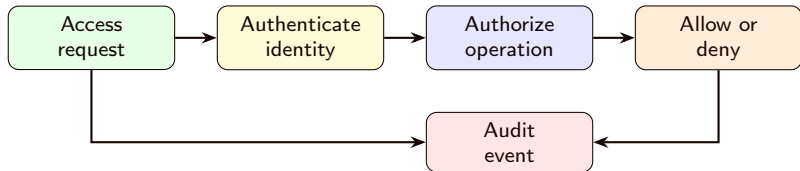
Question

Audit independently records and reviews security-relevant activity to test whether controls are adequate and whether behavior matches policy.

Hospital example

The privacy office reviews accesses to VIP patient records and flags staff members who opened records without a treatment, payment, or operations reason.

Scheme: AAA Flow



Important

Authentication alone is not enough. A valid identity can still request an operation that policy does not allow.

Recap: AAA

Takeaways

- Authentication proves identity or device legitimacy.
- Authorization decides permitted actions.
- Audit creates accountability and supports incident investigation.
- Strong systems keep these functions connected but conceptually separate.

Policy Design Principles

Section Context: Policy Design Principles

What we are talking about

A policy is not only a table of permissions. It also defines assumptions, defaults, delegation rules, conflict handling, and administrative power.

Hospital lens

Bad policy design can either block urgent care or expose sensitive data. The goal is controlled flexibility: enough access for care, enough restriction for privacy and safety.

Reliable Input

Concept

Access control assumes that the inputs used for decisions are reliable: identity, role, device, location, time, patient relationship, and requested operation.

Hospital example

If the EHR trusts a forged department value, an attacker could make a normal account appear to be part of the intensive-care unit. Reliable identity and context data are part of the control.

Fine-Grained and Coarse-Grained Rules

Concept

Policies may be coarse-grained, such as access to an application, or fine-grained, such as access to a single field in a record. Real systems usually need both.

Hospital example

A billing clerk may open the patient account but should not see psychotherapy notes. A physician may see clinical notes but not modify billing codes.

Least Privilege

Concept

Least privilege means granting only the permissions needed for the current task [Saltzer and Schroeder, 1975].

Hospital example

A temporary radiology intern receives read access to imaging studies for assigned patients, not administrator access to the PACS database.

Separation of Duty

Concept

Separation of duty divides sensitive authority across multiple people or roles so that one person cannot complete a dangerous action alone.

Hospital example

One administrator requests creation of a high-privilege EHR account, but a different administrator must approve it before the account becomes active.

Open and Closed Policies

Two defaults

An **open policy** permits access unless a rule denies it. A **closed policy** denies access unless a rule permits it.

Hospital example

For clinical records, St. Isidore uses a closed default: no staff member sees a patient file unless a role, assignment, or break-glass emergency rule permits it.

Policy Conflicts



Concept

Multiple policies may apply to the same resource. A system must define how conflicts are resolved: for example, whether deny rules override allow rules.

Hospital example

A doctor is part of the cardiology team, but a special privacy restriction marks a patient record as sensitive. The EHR needs a clear conflict rule before deciding access.

Administrative Policies and Dual Control

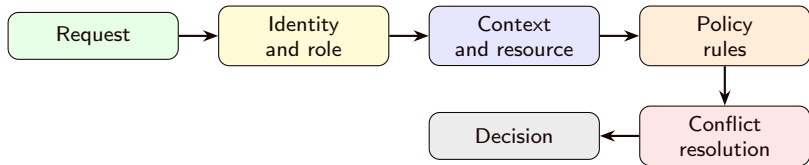
Concept

Administrative policies specify who may add, remove, or modify permissions. **Dual control** requires two or more people to approve especially sensitive actions.

Hospital example

Changing the emergency department's access rules requires approval from both IT security and the clinical governance lead.

Scheme: Policy Evaluation



Reading the scheme

Policy evaluation is a chain. Weak input, unclear rules, or undefined conflicts can all produce unsafe access decisions.

Recap: Policy Design Principles

Takeaways

- Least privilege limits blast radius.
- Separation of duty and dual control reduce abuse of sensitive powers.
- Closed policies are usually safer for clinical and personal data.
- Conflict rules and administrative rules are part of the policy.

Subjects, Objects, and Rights

Section Context: Subjects, Objects, and Rights



What we are talking about

Before comparing access-control models, we need the vocabulary used by all of them: **subjects**, **objects**, and **access rights**.

Hospital lens

The same person may act as different subjects at different times: a physician in a clinical role, a researcher in a research role, or an administrator in a maintenance role.

Subjects

Concept

A **subject** is an active entity that requests access to an object. It may be a user, process, service, device, or application.

Hospital example

Subjects include a nurse using the EHR, a lab analyzer sending results, a backup service reading database files, and an API gateway calling the patient portal.

Owner, Group, World

Common classes

Many systems organize subjects into **owner**, **group**, and **world**. The owner has special control, groups collect shared permissions, and world represents everyone else.

Hospital example

A discharge-template file may be owned by the clinical documentation lead, writable by the documentation team, and readable by all clinicians.

Objects



Concept

An **object** is a protected resource that contains, receives, or controls information.

Hospital example

Objects include EHR records, lab results, PACS images, medication orders, audit logs, API endpoints, database tables, report files, and device configuration screens.

Access Rights

Concept

An **access right** describes the operation a subject may perform on an object.

- **Read:** view or copy information.
- **Write:** add or modify information.
- **Execute:** run a program or invoke an operation.
- **Delete:** remove an object.
- **Create:** make a new object.
- **Search:** list or discover objects.

Rights Need Context

Important

The meaning of a right depends on the object. “Write” on a note, “write” on a medication order, and “write” on an audit log have very different risk.

Hospital example

A nurse may write vital signs. Only a prescriber may write medication orders. Almost nobody should write audit logs directly.

Recap: Subjects, Objects, and Rights

Takeaways

- Subjects request operations.
- Objects are protected resources.
- Rights describe allowed operations.
- Healthcare policies must treat clinical context as part of the meaning of access.

Discretionary Access Control

Section Context: DAC

What we are talking about

Discretionary Access Control bases decisions on subject identity and permissions. It is called discretionary because a subject with sufficient rights may delegate access to another subject.

Hospital lens

A department head who owns a shared protocol folder may grant read access to a new resident. That delegation is useful, but it must be governed to avoid uncontrolled spread.

Access Matrix



Concept

DAC is often explained with an **access matrix**. Rows are subjects, columns are objects, and each cell lists the rights that subject has over that object.

Hospital example

The row for a lab technician may include “write” for lab-result entries but only “read” for the patient demographics needed to label the result.

Scheme: Access Matrix

Subject	EHR note	Lab result	Audit log
Ward nurse	Read, write vitals	Read	No access
Lab technician	Read demographics	Create, write	No access
Auditor	Read metadata	Read metadata	Read

Reading the matrix

The matrix is clear conceptually, but in real hospitals it becomes huge and sparse.

ACLs: Matrix by Columns

Concept

An **Access Control List** stores permissions by object: for each resource, it lists the subjects and their rights.

Hospital example

The ACL for a PACS study lists the radiologist, assigned clinical team, and image-export service, with different rights for viewing, annotating, and exporting.

Capabilities: Matrix by Rows

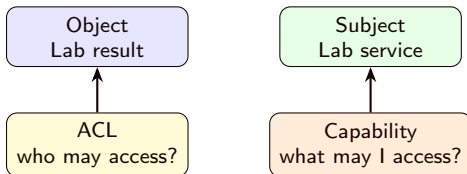
Concept

A **capability** stores permissions by subject: for each subject, it lists the objects that the subject may access and the rights granted.

Hospital example

A service account may carry a signed capability allowing it to submit lab results to a specific API endpoint, but not to read patient histories.

Scheme: ACLs and Capabilities



Trade-off

ACLs make it easy to ask who can access one object. Capabilities make it easy to ask what one subject can access.

Protecting Capabilities

Important

A capability must be protected from forgery and tampering. Systems may store it in protected OS memory or use cryptographic tokens such as message authentication codes.

Hospital example

If a lab device can forge a capability token, it might send results for departments it should not serve. Signed or MAC-protected tokens make that harder.

Notebook: DAC Toy Model

Practical example

Open `lesson-03/examples/01_dac_toy_model.ipynb` after the DAC section.

What students should notice

The notebook represents the same hospital policy as an access matrix and as ACLs, then shows how delegation changes a decision.

Important

This is only a teaching model. Real systems usually provide DAC or ACL mechanisms already; administrators decide the sharing policy and review it.

Recap: DAC

Takeaways

- DAC decisions are based on identity and assigned rights.
- Delegation is powerful but can spread access too widely.
- Access matrices are conceptual; ACLs and capabilities are practical decompositions.
- Capability integrity is essential in distributed systems.

Mandatory Access Control

Section Context: MAC

What we are talking about

Mandatory Access Control uses centrally enforced labels and clearances. Users cannot simply delegate access to others when the labels do not permit it.

Hospital lens

Some clinical data may need stronger controls than ordinary role permissions: psychiatric notes, VIP records, infectious-disease investigations, or research datasets under strict agreements.

Labels and Clearances

Concept

Objects receive **security labels** describing sensitivity. Subjects receive **clearances** describing what sensitivity they may access.

Hospital example

A note labelled “restricted mental health” may require a clinician clearance for that department and a valid care relationship.

Dominance

Concept

A subject may read an object only if the subject **dominates** the object: the subject has a sufficient rank and the required compartments.

Hospital example

A senior infectious-disease physician may access records tagged for the outbreak investigation. A cardiologist with a higher clinical title but without that compartment may still be denied.

Rank and Compartment

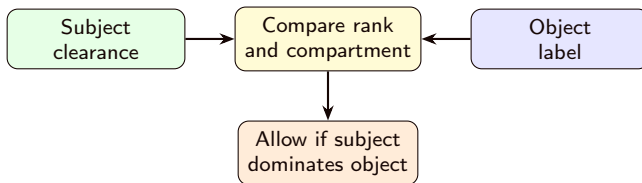
Two dimensions

Rank expresses level of sensitivity. **Compartment** expresses membership in a specific project, ward, study, or controlled domain.

Hospital example

`<restricted; oncology-trial>` requires enough sensitivity clearance and membership in the oncology-trial compartment.

Scheme: MAC Decision



Important

MAC is useful when the organization must prevent unauthorized information flows, even if an individual user would like to share the resource.

MAC Example Decisions

Subject clearance	Object label	Decision
<restricted; oncology>	<confidential; oncology>	Allow
<restricted; cardiology>	<confidential; oncology>	Deny: wrong compartment
<internal; oncology>	<restricted; oncology>	Deny: rank too low

Hospital example

The decision is not just seniority. The subject must have both enough level and the right clinical or project compartment.

Notebook: MAC Toy Model

Practical example

Open `lesson-03/examples/02_mac_toy_model.ipynb` after the MAC section.

What students should notice

The notebook compares subject clearances with object labels. Changing a label can deny access without changing the user's identity.

Important

This is only a teaching model. Real MAC enforcement is supplied by platforms such as operating systems, database engines, or specialized security products.

Recap: MAC

Takeaways

- MAC uses labels on objects and clearances on subjects.
- Access depends on rank and compartment.
- Users cannot freely delegate labelled information.
- MAC is strict, powerful, and administratively demanding.

Role-Based Access Control

Section Context: RBAC

What we are talking about

Role-Based Access Control assigns permissions to roles rather than directly to individual users. Users receive roles according to their responsibilities.

Hospital lens

Hospitals have many users and many resources, but a smaller set of job functions: ward nurse, attending physician, lab technician, pharmacist, registrar, auditor, and system administrator.

Why RBAC Fits Organizations

Concept

Users change often. Permissions attached to job functions change less often. RBAC reduces the administrative burden by managing role assignments and role permissions separately.

Hospital example

When a new nurse joins the emergency department, IT assigns the “ED nurse” role instead of manually granting every permission needed for triage, vitals, and documentation.

Scheme: RBAC Mapping



Reading the scheme

RBAC answers access requests through the active role, not only the user's personal identity.

RBAC0: Core Model

Core entities

RBAC0 contains **users**, **roles**, **permissions**, and **sessions**. A session maps a user to the roles activated for a specific task.

Hospital example

Dr. Rossi may have both “cardiologist” and “researcher” roles, but during a clinical session only the cardiologist role should be active.

Sessions Matter

Concept

A user may be assigned multiple roles, but a session should activate only the roles needed now. This supports least privilege.

Hospital example

The same physician does not need research-export permissions while prescribing medication in the emergency department.

RBAC1: Role Hierarchies

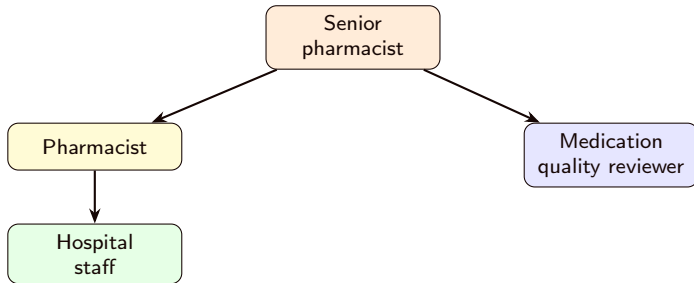
Concept

RBAC1 adds role hierarchies. A senior role can inherit permissions from subordinate roles, reducing duplication.

Hospital example

“Senior pharmacist” inherits normal pharmacist permissions and adds authority to approve high-risk medication substitutions.

Scheme: Role Hierarchy



Reading the scheme

Hierarchies simplify shared permissions, but inherited privileges must still respect least privilege.

RBAC2: Constraints

Concept

RBAC2 adds constraints that express organizational policy, such as mutually exclusive roles, cardinality limits, and prerequisite roles.

Hospital example

The same user should not both request and approve creation of a privileged EHR administrator account.

Mutually Exclusive Roles

Concept

Mutual exclusion prevents one user or one session from holding roles that should not be combined. This supports separation of duty.

Hospital example

A user may not be both “controlled-drug inventory clerk” and “controlled-drug audit approver” for the same reporting period.

Cardinality and Prerequisites

Concept

Cardinality limits how many users may hold a role or how many roles may grant a privilege. **Prerequisite roles** require a user to hold one role before receiving another.

Hospital example

Only two users may hold the “break-glass policy administrator” role. A clinician must first be an attending physician before becoming an ICU attending.

RBAC3 and NIST RBAC



Concept

NIST standardized RBAC around core RBAC, hierarchical RBAC, and separation-of-duty relations [Ferraiolo et al., 2001]. The model also describes administrative, system-support, and review functions.

Hospital example

Administrators create roles and assignments; the EHR checks permissions during sessions; auditors review which users, roles, and permissions exist.

Static and Dynamic Separation of Duty

Two controls

Static separation of duty prevents conflicting role assignments.

Dynamic separation of duty prevents conflicting roles from being active in the same session.

Hospital example

A person may be assigned both clinician and researcher roles, but cannot activate both when exporting identifiable clinical data for a study.

Notebook: RBAC Toy Model

Practical example

Open `lesson-03/examples/03_rbac_toy_model.ipynb` after the RBAC section.

What students should notice

The notebook separates users, roles, permissions, and sessions. It shows that changing the active session can change the access decision.

Important

This is only a teaching model. In real EHRs and identity platforms, administrators design roles, assign users, set constraints, and review access.

Recap: RBAC

Takeaways

- RBAC assigns permissions to roles, then users to roles.
- Sessions activate only the roles needed for the current task.
- Hierarchies reduce duplication but can accidentally accumulate privilege.
- Constraints express least privilege and separation of duty.

Choosing and Combining Models

Section Context: Choosing Models

What we are talking about

DAC, MAC, and RBAC are not mutually exclusive. Real healthcare systems often combine them across operating systems, applications, databases, devices, and networks.

Hospital lens

An EHR can use RBAC for clinical roles, DAC-like ACLs for document sharing, MAC-like labels for highly sensitive notes, and audit rules for accountability.

Comparison

Model	Main basis	Strength	Main caution
DAC	Identity and delegated rights	Flexible sharing	Access can spread too widely
MAC	Labels and clearances	Strong information-flow control	Rigid and costly to administer
RBAC	Organizational roles	Scales with job functions	Role explosion and inherited privilege

Notebook: Comparing Models

Practical example

Open `lesson-03/examples/04_compare_models.ipynb` after the comparison slide.

What students should notice

The same request can be allowed by DAC, denied by MAC, and allowed by RBAC, because each model asks a different policy question.

Important

The notebooks explain concepts, not production engineering. In practice, system administrators select and configure the access-control policy provided by the real system.

Emergency Access

Concept

Healthcare sometimes needs **break-glass** access: temporary emergency access that bypasses normal restrictions but creates strong audit evidence.

Hospital example

An emergency physician can open an unconscious patient's allergy history outside normal assignment rules. The access is logged, justified, time-limited, and reviewed.

Access Control and GDPR

Connection

Access control supports confidentiality, integrity, availability, accountability, and data minimization. It helps ensure that personal health data is processed only by authorized people for authorized purposes.

Hospital example

Audit logs and role assignments help St. Isidore demonstrate that access to patient records is controlled, reviewed, and aligned with operational necessity.

Final Recap

What to remember

- Access control mediates use of protected resources.
- AAA separates identity proof, permission decisions, and accountability.
- Good policy design includes least privilege, separation of duty, conflict handling, and administration.
- DAC, MAC, and RBAC provide different ways to model and enforce access.
- Healthcare systems usually combine models because care workflows are complex.

References I

[Ferraiolo et al., 2001] Ferraiolo, D. F., Sandhu, R., Gavrila, S., Kuhn, D. R., and Chandramouli, R. (2001).

Proposed nist standard for role-based access control.

Technical report, National Institute of Standards and Technology

[https://csrc.nist.gov/publications/detail/conference-paper/2001/10/01/](https://csrc.nist.gov/publications/detail/conference-paper/2001/10/01/proposed-nist-standard-for-role-based-access-control/final)

[proposed-nist-standard-for-role-based-access-control/final](https://csrc.nist.gov/publications/detail/conference-paper/2001/10/01/proposed-nist-standard-for-role-based-access-control/final).

[Saltzer and Schroeder, 1975] Saltzer, J. H. and Schroeder, M. D. (1975).

The protection of information in computer systems.

Proceedings of the IEEE, 63(9):1278–1308

DOI:10.1109/PROC.1975.9939.

References II

[Shirey, 2007] Shirey, R. (2007).
Internet security glossary, version 2.
RFC 4949, Internet Engineering Task Force

<https://www.rfc-editor.org/rfc/rfc4949>.